Zajęcia 5: Bezpieczeństwo danych, AI, incydent i strategia ryzyka

Witchak Modeling, zespół Ziemniaczki: I. Skrypnyk, M. Szyksznia, K. Witczak, O. Wilk

Część 1. Bezpieczeństwo danych

Cecha	Baza klientów i aplikacji produkcyjnych	Kod źródłowy projektów	Dokumentacja i materiały projektowe
Gdzie jest przechowywany	Baza w chmurze hostingowej, dostęp tylko przez aplikację po HTTPS.	Prywatne repozytoria w organizacji GitHub, lokalne kopie robocze na laptopach programistów.	Serwer plików w biurze (VLAN 20) oraz Figma i UXPin w chmurze.
Kto ma dostęp	Aplikacja przez konto bez praw administratora bazy, administrator baz i DevOps. Programiści tylko do kopii testowej z danymi zanonimizowanymi.	Programiści według projektów, Tech Lead jako właściciel organizacji, konto CI/CD z tokenem o minimalnych uprawnieniach.	Grupy projektowe, graficy, manager projektu. Klient tylko przez link do swojego prototypu, z hasłem i datą ważności.
Czy szyfrować	Tak. TLS w transmisji, szyfrowanie bazy i kopii, hasła wyłącznie jako skróty (bcrypt lub Argon2).	Tak. HTTPS lub SSH w transmisji, szyfrowane dyski laptopów. Hasła i klucze API nigdy w repozytorium, tylko w menedżerze sekretów.	Tak. Szyfrowane dyski laptopów i kopia zewnętrzna. Materiały objęte NDA w osobnych, ograniczonych katalogach.
Jak długo przechowywać	Dane osobowe tylko przez czas umowy z klientem i okres wynikający z przepisów, potem usunięcie lub przekazanie klientowi (RODO, minimalizacja).	Przez czas utrzymania strony. Po zakończeniu współpracy przekazanie klientowi zgodnie z umową i archiwum tylko w zakresie, na który umowa pozwala.	Przez czas projektu i gwarancji. Umowy i dokumenty rozliczeniowe 5 lat (przepisy podatkowe), materiały klienta usuwane po zakończeniu umowy.
Kopia zapasowa	Codziennie, kopia szyfrowana i niezmienialna w osobnym koncie chmury (3-2-1), test odtwarzania co kwartał.	Cotygodniowy eksport repozytoriów do kopii zewnętrznej, dodatkowo klony u programistów.	Serwer kopii w biurze i kopia w chmurze, jedna kopia offline (ochrona przed ransomware, R11). Eksport z Figma i UXPin co tydzień.
Skutki ujawnienia (P)	Naruszenie RODO, zgłoszenie do UODO w 72 h, kary, roszczenia klientów i ich użytkowników, utrata zaufania.	Kradzież własności intelektualnej, naruszenie umów z klientami, a przy kluczach w kodzie bezpośredni dostęp atakującego do produkcji.	Ujawnienie projektów przed premierą, naruszenie NDA, kary umowne.
Skutki modyfikacji (I)	Fałszywe dane klientów, podmienione dane logowania lub numery kont, oszustwa wobec użytkowników.	Złośliwy kod wdrożony na strony klientów (R19), atak na ich użytkowników, odpowiedzialność firmy.	Praca na złej wersji projektu, błędy u klienta, spory o zakres zamówienia.
Skutki utraty dostępu (D)	Strony klientów przestają działać, kary za naruszenie SLA.	Brak możliwości wdrażania poprawek, w tym poprawek bezpieczeństwa, opóźnienia projektów.	Zatrzymanie pracy grafików i projektantów, niedotrzymane terminy.

Część 2. Wykorzystanie AI

Pytanie	Odpowiedź
1. Jakie dane mogą trafiać do AI?	Fragmenty kodu i komunikaty błędów, treści stron, opisy projektów, briefy i dokumenty od klientów do streszczenia, a w chatbocie pytania użytkowników stron.
2. Czy mogą być wśród nich dane poufne?	Tak. Kod klientów, klucze API i hasła w plikach konfiguracyjnych, dane osobowe z bazy przy debugowaniu, umowy i projekty objęte NDA, w chatbocie dane osobowe wpisane przez użytkowników.
3. Kto może korzystać?	Asystent kodu: programiści. Czat: wszyscy pracownicy, tylko na kontach firmowych z MFA. Chatbot: użytkownicy stron klientów, czyli osoby spoza firmy, dlatego ma najwęższe uprawnienia.
4. Co użytkownik może przypadkowo ujawnić?	Wklejony plik .env z hasłami, zrzut bazy z danymi klientów, cała umowa zamiast jednego akapitu, nazwę klienta i szczegóły projektu przed premierą, zrzut ekranu z widocznymi danymi logowania.
5. Czy wynik AI jest automatycznie poprawny?	Nie. AI może podać nieprawdziwe fakty, kod z podatnościami, nieistniejące biblioteki albo treść naruszającą prawa autorskie. Wynik to propozycja, za którą odpowiada pracownik, który go użył.
6. Zasady dla organizacji	Tylko zatwierdzone narzędzia na kontach firmowych, z umową powierzenia i wyłączonym trenowaniem na naszych danych, bez prywatnych kont. Zakaz wklejania haseł, kluczy, danych osobowych i dokumentów z NDA bez zgody klienta, dane anonimizowane. Kod z AI przechodzi ten sam przegląd i testy co kod pisany ręcznie. Fakty i treści sprawdza człowiek przed publikacją. Chatbot informuje, że jest AI (AI Act), nie ma dostępu do bazy klientów ani do działań na kontach. Szkolenie przed nadaniem dostępu, przegląd zasad co pół roku.

Ryzyka związane z AI

ID	Ryzyko	Zabezpieczenie	Praw.	Skutek	Poziom
R24	Ujawnienie danych poufnych lub kodu klientów przez wklejenie ich do publicznego narzędzia AI (również na prywatnym koncie)	Konta firmowe z umową powierzenia, zakaz danych poufnych, blokada niezatwierdzonych narzędzi, szkolenie	3	4	12
R25	Wdrożenie kodu z AI z podatnością lub z nieistniejącą biblioteką podstawioną przez atakującego	Przegląd kodu, skanowanie SAST i zależności w CI, zatwierdzona lista bibliotek	3	4	12
R26	Prompt injection w chatbocie na stronie klienta: ujawnienie danych lub instrukcji, szkodliwe odpowiedzi	Brak dostępu chatbota do bazy i kont, filtr odpowiedzi, logowanie rozmów, testy przed wdrożeniem	2	4	8
R27	Naruszenie praw autorskich przez teksty lub grafiki z AI użyte na stronach klientów	Sprawdzanie treści przed publikacją, informowanie klienta o użyciu AI, licencje narzędzi	3	3	9

Część 3. Incydent: wyciek danych klientów z bazy przez SQL Injection (R1)

Etap	Działania
1. Detection	Alert z monitoringu (zajęcia 3): nietypowo duża liczba zapytań do bazy i błędy SQL w logach WAF. Inne możliwe źródła: zgłoszenie klienta, skargi użytkowników na phishing, dane wystawione na forum. Pierwsza osoba, która zauważy problem, zgłasza go Liderowi Projektu, który zakłada rejestr incydentu z godziną wykrycia.
2. Analysis	Zabezpieczenie dowodów: kopia logów serwera WWW, WAF i bazy oraz migawka maszyny przed zmianami. Ustalenie wektora (który formularz, jakie zapytania), zakresu (tabele, liczba rekordów, czy były hasła i dane osobowe), okresu (od kiedy) i tego, czy atakujący coś zmienił lub zostawił (konta, webshell). Na tej podstawie ocena ryzyka dla osób, których dane dotyczą.
3. Containment	Strona w trybie serwisowym lub wyłączenie samego formularza, reguła WAF blokująca wzorzec ataku i adresy atakującego. Zmiana hasła konta aplikacji do bazy i kluczy API, unieważnienie sesji. Sprawdzenie, czy ten sam kod nie działa na stronach innych klientów.
4. Eradication	Poprawka kodu: zapytania parametryzowane i walidacja danych wejściowych. Aktualizacja przestarzałej bazy (podatność z rejestru R1). Usunięcie kont i plików dodanych przez atakującego, skan podatności wszystkich stron z tym samym szablonem.
5. Recovery	Wdrożenie poprawionej wersji po testach, przywrócenie danych z kopii, jeśli zostały zmienione. Wymuszenie zmiany haseł użytkownikom strony, wzmożony monitoring przez 30 dni. Powiadomienia: klient jako administrator danych bez zbędnej zwłoki (art. 33 ust. 2 RODO), klient zgłasza naruszenie do UODO w 72 h, a przy wysokim ryzyku informuje użytkowników (art. 34). Komunikat przygotowuje Lider Projektu razem z klientem.
6. Lessons Learned	Spotkanie w ciągu 2 tygodni i krótki raport: co zadziałało, ile trwało wykrycie i reakcja. Zmiany: test penetracyjny przed każdym wdrożeniem i raz w roku, skanowanie SAST w CI, WAF dla wszystkich stron, harmonogram aktualizacji baz, procedura incydentu przećwiczona raz w roku, aktualizacja rejestru ryzyka i oceny R1.

Część 4. Strategia postępowania z ryzykiem

ID	Ryzyko	Strategia	Uzasadnienie
R1	Wyciek danych klientów z bazy (20)	Reduce, resztę Transfer	Bazy nie da się zlikwidować, to podstawa usług. Ograniczamy: aktualizacje, WAF, testy penetracyjne, szyfrowanie, najmniejsze uprawnienia. Ryzyko resztkowe (koszty obsługi naruszenia, roszczenia) przenosimy na ubezpieczenie cyber i zapisy w umowach z klientami.
R3	Przejęcie laptopa pracownika w pracy hybrydowej (16)	Reduce	Praca hybrydowa jest modelem firmy, więc nie unikamy. MFA, EDR, szyfrowanie dysków, brak praw administratora, szkolenia z phishingu tanio obniżają prawdopodobieństwo i skutek.
R5	Błędna konfiguracja chmury (16)	Reduce	Chmura jest niezbędna. Lista kontrolna, zasoby prywatne domyślnie, alerty przy zmianie na publiczne i przegląd uprawnień co kwartał.
R10	Hasła i klucze API w repozytorium GitHub (16)	Avoid	Eliminujemy samo działanie, które tworzy ryzyko: sekrety tylko w menedżerze sekretów, a ochrona przed wypchnięciem sekretu w GitHub blokuje commit. Bez sekretów w kodzie nie ma czego wykraść z repozytorium.
R22	Spear phishing na podstawie informacji publicznych (16)	Reduce	Informacji publicznych nie da się całkiem ukryć, bo firma potrzebuje portfolio i kontaktu. Ograniczamy szczegóły na stronie, wdrażamy SPF, DKIM, DMARC, szkolenia i potwierdzanie przelewów oraz zmian kont drugim kanałem.

Część 5. Kompletność projektu

Element	Status	Gdzie
1. Opis organizacji	jest	zajęcia 1
2. Zakres projektu	jest	zajęcia 1
3. Architektura środowiska	jest	zajęcia 3
4. Najważniejsze aktywa	jest	zajęcia 2
5. Rejestr zagrożeń i ryzyka	jest	zajęcia 2, 3, 4, 5 (R1 do R27)
6. TOP 5 ryzyk	jest	zajęcia 5, część 4
7. Proponowane zabezpieczenia	jest	zajęcia 3 i 4
8. Chmura, mobile, IoT	jest	zajęcia 4
9. Bezpieczeństwo danych	jest	zajęcia 5, część 1
10. Analiza wykorzystania AI	jest	zajęcia 5, część 2
11. Scenariusz reagowania na incydent	jest	zajęcia 5, część 3
12. Rekomendacje	jest	zajęcia 5, część 5

Rekomendacje dla organizacji

Nr	Rekomendacja	Ryzyka	Termin
1	MFA na wszystkich kontach, w pierwszej kolejności administratorzy, GitHub, chmura, poczta i VPN	R3, R5, R7, R8	od razu
2	Aktualizacja bazy danych, WAF i test penetracyjny wszystkich stron klientów	R1	1 miesiąc
3	Sekrety tylko w menedżerze sekretów, ochrona przed wypchnięciem sekretu i skan historii repozytoriów	R10, R19	1 miesiąc
4	Kopie 3-2-1 z kopią niezmienialną i offline, kwartalny test odtwarzania	R4, R11, R18	1 miesiąc
5	EDR i szyfrowanie dysków na wszystkich laptopach, brak praw administratora	R3, R13	3 miesiące
6	Szkolenie z phishingu i AI dla całego zespołu, SPF, DKIM, DMARC, potwierdzanie przelewów drugim kanałem	R22, R24	3 miesiące
7	Polityka AI z listą zatwierdzonych narzędzi i przeglądem kodu z AI	R24, R25, R27	3 miesiące
8	Centralny monitoring i alerty, procedura incydentu ćwiczona raz w roku	R14, R1	6 miesięcy
9	Kwartalny przegląd uprawnień i kont byłych pracowników, segmentacja VLAN	R9, R17	6 miesięcy